

UNIVERSITY OF MINES AND TECHNOLOGY, TARKWA



DEPARTMENT OF CUBERSECURITY AND INFORMATION SYSTEM

CY376: NETWORK MONITORING, SECURITY AND AUDITING
Conducting a Full Network Security Audit Against ISO 27001
Controls

End-of-Semester Project Report

Track: Blue Team

Aboyinga Ahmed Atogyine

Index Number: FCM.41.018.004.23

Class: CY3A

Course Code: CY376

Date: 3rd August 2026

<https://github.com/Hustle4dollar/network-audit>

Table of Contents

Abstract.....	3
Introduction.....	4
Literature and Tooling Review.....	6
Methodology.....	7
Implementation.....	9
Results and Findings.....	12
Analysis and Recommendations.....	14
Conclusion.....	16
References.....	16
Appendices.....	17

Abstract

Organizations increasingly depend on interconnected network infrastructure to deliver core services, which makes the security posture of that infrastructure a direct business risk rather than a purely technical concern. This project undertakes a network security audit of a controlled laboratory environment, assessing it against selected control domains of the ISO/IEC 27001 Annex A framework. The aim was to determine the extent to which the lab environment, representing a small organizational network segment, complied with recognized information security controls, and to produce actionable, prioritized recommendations for remediation.

The audit identified 30 open network services on the assessed server, six of which were documented as formal findings, including an unauthenticated remote shell, cleartext credential transmission via Telnet, and an FTP service with a publicly known backdoor vulnerability. No host-based firewall enforcement was in place at the start of the audit. A default-deny firewall policy was implemented and verified as a demonstration remediation. The headline recommendation is immediate removal of the unauthenticated shell service and disabling of Telnet, followed by a systematic review of all remaining exposed services against actual business need.

Introduction

Background

Network security auditing is the structured process of evaluating an organization's network infrastructure, configurations, and operating practices against a defined set of security requirements. Rather than relying on ad-hoc judgments of what constitutes 'good' security, a formal audit measures an environment against an established standard, producing findings that are traceable, comparable, and defensible. ISO/IEC 27001 is one of the most widely adopted standards for this purpose. It defines an Information Security Management System (ISMS) and, through its Annex A, a catalogue of security controls spanning organizational, people, physical, and technological domains. Annex A does not prescribe specific technical implementations; rather, it states control objectives that an organization must demonstrate it has addressed, leaving the choice of implementation to the organization's risk context.

For a network-focused audit, the most directly relevant control areas are those governing asset management, access control, operations security, and communications security, since these dictate how network assets are identified, how access to them is restricted, how their operation is monitored and maintained, and how data moves securely between them.

Project Objectives

This project set out to:

- Establish a controlled, isolated network laboratory representative of a small organizational network segment.
- Conduct a technical and configuration-based audit of that environment against a defined subset of ISO/IEC 27001 Annex A controls.
- Document findings with supporting technical evidence (scan output, configuration excerpts, and screenshots).
- Assess the severity and business impact of identified gaps.
- Produce prioritized, actionable remediation recommendations, and where feasible, implement and verify at least one remediation.

Scope

The audit was conducted for a hypothetical client, Meridian Bookkeeping Ltd., a small accounting and bookkeeping firm of approximately fifteen staff that recently digitized its client financial records. The firm operates a single internal Linux server, referred to throughout this report as FIN-SRV-01, which hosts client financial records, a web-based document upload portal, and internal file-sharing services. Meridian Bookkeeping has never undergone a formal security audit and requested an assessment of FIN-SRV-01 ahead of an upcoming compliance renewal.

To provide a safe, reproducible, and legally unambiguous basis for testing, FIN-SRV-01 was represented in the laboratory by a Metasploitable2 virtual machine (192.168.56.4), audited from a Kali Linux workstation (192.168.56.3) acting as the auditor's machine. Both hosts were isolated on a VirtualBox host-only network (vboxnet0), with no route to the internet or to the host machine's production network. The organization and its

data are fictional; all technical findings presented in this report were produced directly against this laboratory environment.

The audit scope was limited to four ISO/IEC 27001 Annex A control domains most directly relevant to a network security assessment of a single server asset: A.8 (Asset Management), A.9 (Access Control), A.12 (Operations Security), and A.13 (Communications Security). Organizational controls such as physical security, HR security, and supplier relationship management were considered out of scope, as they fall outside a purely technical network audit and were not observable within the lab environment.

Report Structure

The remainder of this report is organized as follows. Section 2 reviews the standards and tools that shaped the audit methodology. Section 3 describes the laboratory setup and the audit methodology applied. Section 4 details the implementation of the audit environment and the controls tested. Section 5 presents the results and findings. Section 6 analyzes those findings and provides recommendations. Section 7 concludes the report.

Literature and Tooling Review

ISO/IEC 27001 and Annex A

ISO/IEC 27001 is an international standard that specifies requirements for establishing, implementing, maintaining, and continually improving an Information Security Management System. Its Annex A provides a reference set of controls, grouped into thematic areas covering organizational controls, people controls, physical controls, and technological controls. Rather than being audited in isolation, network security sits primarily within the technological control theme, though it is influenced by organizational controls such as asset ownership and risk treatment decisions.

This audit focused on the following control areas, chosen for their direct relevance to a network security assessment:

- A.8 – Asset Management: ensuring assets associated with information and information processing are identified, and appropriate responsibilities for them defined.
- A.9 – Access Control: restricting access to information and information processing facilities based on business and security requirements.
- A.12 – Operations Security: ensuring correct and secure operation of information processing facilities, including protection from malware and logging of events.
- A.13 – Communications Security: protecting information in networks and supporting information processing facilities, including network segregation and secure transfer.

Audit Tooling

Nmap (Network Mapper) is an open-source utility for network discovery and security auditing. It was used in this project to enumerate live hosts, identify open ports, and fingerprint running services, forming the basis of the asset inventory required to assess A.8 and to identify unnecessary or insecure exposed services relevant to A.13.

iptables, the Linux kernel's native packet filtering framework, was used to assess and subsequently harden host-level network access control on the audited target, providing direct evidence relevant to A.13's requirements around network controls and, more broadly, to A.9's access control objectives at the host level.

Test Environment: Metasploitable2

Metasploitable2 is an intentionally vulnerable Linux virtual machine distributed by Rapid7 for security training and tool testing. It ships with a range of outdated services, weak or default credentials, and known misconfigurations, which makes it well suited to producing realistic, reproducible audit findings without any of the legal or ethical concerns associated with testing production or third-party systems. All testing in this project was confined to this isolated, purpose-built target.

Methodology

Lab Setup

The audit environment was built using Oracle VirtualBox as the hypervisor, running on a host machine outside the scope of the audit itself. Two virtual machines were deployed:

- Kali Linux — the auditor's workstation, used to run all scanning and assessment tooling.
- Metasploitable2 — the audited asset, representing an internal organizational server.

Both virtual machines were attached to a VirtualBox host-only network (vboxnet0, address range 192.168.56.2–192.168.56.199), isolating traffic between them from both the internet and the host machine's production network. Kali Linux was assigned 192.168.56.3 and Metasploitable2 (FIN-SRV-01) was assigned 192.168.56.4. This ensured that all testing activity remained within the authorized, isolated lab boundary, consistent with the course's requirement that Blue Team and Red Team activity never touch unauthorized or production systems.

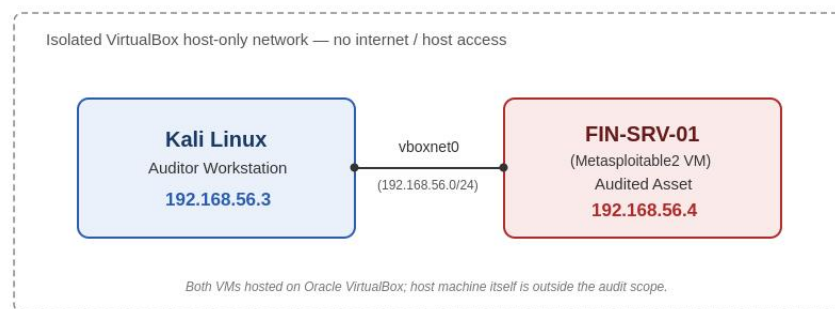


Figure 1: Laboratory network topology — Kali Linux (auditor workstation, 192.168.56.3) and FIN-SRV-01/Metasploitable2 (audited asset, 192.168.56.4) on an isolated VirtualBox host-only network (vboxnet0).

Audit Approach

The audit combined technical scanning with configuration review, structured around the ISO/IEC 27001 Annex A controls defined in the scope. For each control in scope, the following steps were applied:

- Identify the control objective and what evidence would demonstrate compliance or non-compliance.
- Collect technical evidence using the appropriate tool (e.g., Nmap for asset/service discovery, iptables for access control state).
- Compare the observed state against the control objective to determine a compliance status.
- Record the finding, assign a risk rating, and draft a remediation recommendation.
- Where feasible within the project timeframe, implement the recommended remediation and re-test to verify its effect.

Risk Rating Scale

Findings were rated using a simple three-tier scale to keep prioritization consistent across the report:

- High — directly exploitable, or exposes sensitive data/access with no mitigating control.
- Medium — weakens the security posture but requires additional conditions to be exploited.
- Low — a deviation from best practice with limited immediate impact.

Limitations

This audit was conducted within a one-month academic project timeframe using a single-server laboratory environment, and its scope should be read with that constraint in mind. A production audit of an organization such as Meridian Bookkeeping would typically also include interviews with staff and management, a review of written information security policies, physical security controls at the premises, and testing across multiple hosts and network segments rather than a single server. Findings in this report are therefore limited to what could be observed technically from FIN-SRV-01 itself, and should be understood as illustrative of the kind of gaps a full organizational audit would seek to uncover, rather than an exhaustive assessment of Meridian Bookkeeping's overall security posture.

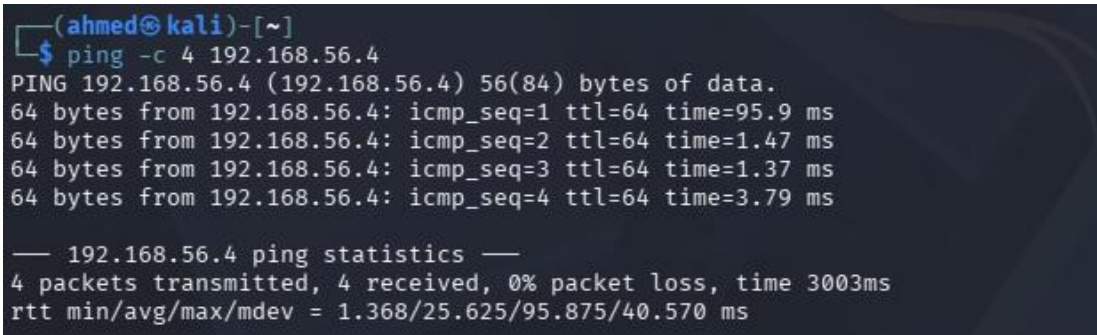
Implementation

This section documents the exact steps and commands used to build the audit environment and carry out testing against FIN-SRV-01, organized by the control area each step relates to.

Network Configuration

Kali Linux and Metasploitable2 were both attached to a VirtualBox host-only network (vboxnet0). Kali received address 192.168.56.3 and Metasploitable2 (FIN-SRV-01) received 192.168.56.4, both confirmed with `ifconfig/ip a` on each host. Connectivity between the two was verified from Kali with:

`ping -c 4 192.168.56.4`



```
(ahmed@kali)-[~]
$ ping -c 4 192.168.56.4
PING 192.168.56.4 (192.168.56.4) 56(84) bytes of data.
64 bytes from 192.168.56.4: icmp_seq=1 ttl=64 time=95.9 ms
64 bytes from 192.168.56.4: icmp_seq=2 ttl=64 time=1.47 ms
64 bytes from 192.168.56.4: icmp_seq=3 ttl=64 time=1.37 ms
64 bytes from 192.168.56.4: icmp_seq=4 ttl=64 time=3.79 ms

— 192.168.56.4 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3003ms
rtt min/avg/max/mdev = 1.368/25.625/95.875/40.570 ms
```

Figure 2: Connectivity verification from Kali (192.168.56.3) to FIN-SRV-01 (192.168.56.4) — 0% packet loss.

Asset and Service Discovery (A.8)

A full TCP port scan with service and version detection was run from Kali against FIN-SRV-01 to build an inventory of active services, the basic evidence required to assess A.8:

`nmap -sV -p- 192.168.56.4`

The `-sV` flag enables service and version detection rather than simply reporting a port as open, and `-p-` instructs Nmap to scan all 65,535 TCP ports rather than only the 1,000 most common ports, since undocumented or forgotten services often run on non-standard ports.

```

└─$ nmap -sV -p- 192.168.56.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 22:26 -0400
Nmap scan report for 192.168.56.4
Host is up (0.00060s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd?     PostgreSQL DB 8.3.0 - 8.3.7
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/dr

```

Figure 3: Nmap service/version scan of FIN-SRV-01 (`nmap -sV -p- 192.168.56.4`), showing the complete set of 30 open TCP ports.

Access Control and Communications Security Assessment (A.9 / A.13)

The host-based firewall state on FIN-SRV-01 was checked using iptables, the native Linux packet-filtering framework:

```
sudo iptables -L -n
```

This returned Chain INPUT (policy ACCEPT), Chain FORWARD (policy ACCEPT), and Chain OUTPUT (policy ACCEPT), each with no rules defined — indicating no host-based access control was enforced on the server at all.

```

msfadmin@metasploitable:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination

```

Figure 4: Default iptables state on FIN-SRV-01 prior to remediation — policy ACCEPT, no rules.

As a remediation, a least-privilege inbound ruleset was applied directly on FIN-SRV-01:

```
sudo iptables -P INPUT DROP
```

```
sudo iptables -A INPUT -i lo -j ACCEPT
```

```
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

```
sudo iptables -A INPUT -p tcp -s 192.168.56.3 -j ACCEPT
```

The first command changes the default INPUT policy from ACCEPT to DROP, so any traffic not explicitly permitted is denied by default. The second command permits loopback traffic, required for normal local operation. The third permits return traffic for connections the server itself initiated. The fourth explicitly allows inbound TCP traffic only from the auditor's workstation (192.168.56.3), representing a trusted administrative host.

The ruleset was then verified with the same command as before:

```
sudo iptables -L -n
```

This returned Chain INPUT (policy DROP) with the three ACCEPT rules listed above now active, confirming the change was applied successfully.

```
msfadmin@metasploitable:~$ sudo iptables -L -n
Chain INPUT (policy DROP)
target    prot opt source                destination
ACCEPT    all  --  0.0.0.0/0              0.0.0.0/0
ACCEPT    all  --  0.0.0.0/0              0.0.0.0/0      state RELATED,ESTAB
LISHED
ACCEPT    tcp  --  192.168.56.3           0.0.0.0/0

Chain FORWARD (policy ACCEPT)
target    prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target    prot opt source                destination
```

Figure 5: iptables state on FIN-SRV-01 following remediation — policy DROP, least-privilege ruleset applied.

Operations Security (A.12)

Operations security was assessed indirectly through the service versions returned by the Nmap scan above, several of which correspond to software versions with publicly known vulnerabilities (discussed in Results and Analysis). No centralized logging or patch management process was observed on FIN-SRV-01 during testing.

Results and Findings

This section presents the technical evidence gathered during the audit of FIN-SRV-01, organized by control area. Each finding is captioned, explained, and cross-referenced against the corresponding Annex A control.

Summary of Findings

Control	Current State	Compliant?	Risk Level	Recommendation
A.13	Telnet (port 23) open, transmits credentials in cleartext	No	High	Disable Telnet; require SSH (already available on port 22)
A.9	Unauthenticated shell service on port 1524 ('Metasploitable root shell')	No	High	Identify and remove the listening service; audit for unauthorized access
A.12	vsftpd 2.3.4 on port 21 — version with known backdoor (CVE-2011-2523)	No	High	Upgrade FTP service or disable if not required
A.9 / A.13	MySQL (3306) and PostgreSQL (5432) reachable from the network rather than localhost-only	No	Medium	Restrict database bind address to localhost or trusted hosts only
A.9	Legacy r-services (rlogin/rsh/rexec, ports 512-514) active	No	Medium	Disable r-services; use SSH for all remote administration
A.13	No host-based firewall enforced on FIN-SRV-01 (iptables policy ACCEPT, no rules)	No	High	Implement default-deny inbound policy with explicit allow rules (remediated during this audit — see below)

A.8 — Asset Management Findings

A full port scan of FIN-SRV-01 (nmap -sV -p- 192.168.56.4) identified 30 open TCP ports, spanning web, mail, file-sharing, database, and remote-access services. No documentation of an expected or approved service inventory existed prior to this audit, meaning the organization had no baseline against which to judge whether this exposure was intended. This scale of exposure on a single server, most of which is unlikely to be required for the server's stated purpose of hosting client records and a document upload portal, represents a significant gap in asset and service management.

(See Figure 3, Section 4.2 — Nmap service/version scan of FIN-SRV-01, showing the open ports enumerated during this audit.)

A.9 / A.13 — Access Control and Communications Security Findings

Several of the services identified above directly affect access control and communications security. Telnet (port 23) transmits authentication credentials and session data unencrypted, exposing them to interception on the network. Port 1524 was identified by Nmap as a 'Metasploitable root shell' — an unauthenticated shell accessible without any credentials, the most severe single finding of this audit. Legacy remote-access services (rlogin, rsh, rexec on ports 512–514) were also active; these protocols predate modern authentication standards and are not considered acceptable for administrative access under current practice.

A check of the host-based firewall state (`sudo iptables -L -n`) found all three default chains set to policy ACCEPT with no rules defined, meaning no filtering was applied to any of the exposed services described above.

(See Figure 4, Section 4.3 — default iptables state on FIN-SRV-01, policy ACCEPT, no rules.)

As documented in Implementation, a default-deny inbound ruleset was applied and verified, changing the INPUT policy to DROP with explicit allow rules for loopback traffic, established connections, and the auditor's trusted workstation only.

(See Figure 5, Section 4.3 — iptables state on FIN-SRV-01 following remediation, policy DROP, least-privilege ruleset applied.)

A.12 — Operations Security Findings

Version detection during the port scan identified vsftpd 2.3.4 running on port 21. This specific version is publicly documented as containing a backdoor (CVE-2011-2523) that allows unauthenticated remote command execution. Running software with a known, unpatched critical vulnerability indicates an absence of a patch management or vulnerability tracking process for FIN-SRV-01.

Additional Access Control Findings

Two further findings from the same scan warrant separate discussion, as each represents a distinct access control weakness rather than a variant of those already discussed. The legacy remote-access services rlogin, rsh, and rexec (ports 512, 513, and 514 respectively) were found active on FIN-SRV-01. These protocols originate from an era before modern authentication mechanisms were standard, and in many configurations rely on host-based trust (matching source IP or hostname) rather than verified credentials, making them straightforward to abuse from any host that can reach the server or spoof a trusted address. Their presence alongside SSH, which provides equivalent functionality with strong authentication and encryption, indicates these services were never disabled after the base system was provisioned.

Separately, both MySQL (port 3306) and PostgreSQL (port 5432) were found listening on the server's network-facing interface rather than being restricted to local connections only. For a server whose stated purpose is hosting client financial records, a network-reachable database materially increases the pathways available for data exfiltration: an attacker would not need to compromise the web application layer at all if the database itself can be reached and its own authentication is weak or default. No firewall rule or database configuration was found restricting access to either service prior to the remediation applied in this audit.

Analysis and Recommendations

This section interprets the findings presented above in terms of business risk to Meridian Bookkeeping and translates each into a concrete recommendation.

Unauthenticated Root Shell (Port 1524)

This is the single most severe finding in this audit. An unauthenticated shell reachable over the network means anyone with network access to FIN-SRV-01 could obtain command execution without providing any credentials — for a server holding client financial records, this would represent a complete compromise of confidentiality and integrity. Recommendation: identify and immediately disable the listening service; treat this as an incident requiring investigation into whether it was already accessed, not solely a configuration gap.

Cleartext Telnet Access (Port 23)

Telnet transmits usernames and passwords unencrypted. Anyone able to observe network traffic to FIN-SRV-01, including from a compromised host on the same network segment, could recover valid credentials. Recommendation: disable the Telnet service entirely and standardize on the SSH service already present on port 22, with password authentication disabled in favor of key-based authentication.

Outdated FTP Service with Known Backdoor (Port 21)

vsftpd 2.3.4 contains a publicly documented backdoor. Because the vulnerability is public and the fix is simply upgrading the software, continued use of this version indicates no process exists for tracking and patching known vulnerabilities in exposed services. Recommendation: upgrade to a current, supported FTP server version, or replace FTP with SFTP over the existing SSH service if file transfer is still required.

Exposed Database Services (Ports 3306, 5432)

MySQL and PostgreSQL were both reachable over the network rather than restricted to local connections only. For a server described as hosting client financial records, network-reachable databases significantly widen the attack surface for data exfiltration. Recommendation: bind both database services to localhost unless a specific, documented business need requires remote database access, in which case access should be restricted by firewall rule to named application servers only.

Absence of Host-Based Firewall Enforcement (A.13)

Prior to remediation, FIN-SRV-01 enforced no host-based access control whatsoever, meaning every one of the 30 discovered services was reachable by any host that could route to the server. This was addressed directly during this audit: a default-deny inbound policy was applied, allowing only loopback traffic, established connections, and the auditor's trusted workstation. The post-remediation verification (Figure 5) confirmed the new policy took effect. In a production deployment, the single trusted-host rule used here for demonstration purposes would be replaced with rules scoped to each legitimate business need (e.g., allowing the specific IP ranges of staff who require SSH access, and the specific service ports FIN-SRV-01 is actually required to expose).

Prioritized Remediation Roadmap

- Immediate: investigate and remove the unauthenticated shell on port 1524; disable Telnet; upgrade or disable the vulnerable FTP service.
- Short-term (within one to two weeks): restrict database services to localhost or named trusted hosts; disable legacy r-services; formalize the host-based firewall ruleset for production use with least-privilege access per role.
- Long-term (within the next compliance cycle): establish a documented asset and service inventory for FIN-SRV-01 and any future servers, and a recurring patch/vulnerability review process to prevent known-vulnerable software from persisting unnoticed.

Conclusion

This project set out to audit a representative internal server, FIN-SRV-01, against four ISO/IEC 27001 Annex A control domains — Asset Management, Access Control, Operations Security, and Communications Security — using a controlled, isolated laboratory built from Kali Linux and Metasploitable2.

The audit found significant gaps across all four control areas. A full service scan revealed 30 open ports, several running outdated or inherently insecure services, including an unauthenticated shell, cleartext Telnet, and an FTP server with a known backdoor. No host-based firewall enforcement existed on the server prior to this audit, meaning every one of these exposed services was reachable without restriction.

The most significant single gap was the unauthenticated shell on port 1524, which alone would allow complete compromise of the server without any credentials. Beyond this, the pattern across findings — outdated software, unnecessary exposed services, and absent access control — points to a broader lack of a systematic asset and vulnerability management process, rather than a series of unrelated misconfigurations.

As a demonstration of remediation, a default-deny host-based firewall policy was implemented and verified on FIN-SRV-01, showing that at least one class of finding (uncontrolled network access) can be addressed quickly and validated with the same tooling used to discover it. This exercise demonstrated that even a small-scale environment, audited with freely available tools, can surface findings serious enough to warrant an organization's immediate attention, and that ISO/IEC 27001's Annex A structure provides a workable framework for organizing and prioritizing that kind of technical finding into business-relevant risk.

References

International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements.

Rapid7. (n.d.). Metasploitable2. Retrieved from <https://github.com/rapid7/metasploitable2>

Nmap Project. (n.d.). Nmap Reference Guide. Retrieved from <https://nmap.org/book/man.html>

Netfilter Project. (n.d.). The netfilter.org iptables project. Retrieved from <https://www.netfilter.org/projects/iptables/>

Appendices

Full, uncropped tool output and extended code/configuration that would clutter the main body are included here.

Appendix A: Full Nmap Output

Raw output of: `nmap -sV -p- 192.168.56.4 -oN scan_full.txt`, captured directly from the Kali terminal.

```

└─$ nmap -sV -p- 192.168.56.4 -oN scan_full.txt
cat scan_full.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 23:40 -0400
Nmap scan report for 192.168.56.4
Host is up (0.0043s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian Subuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          netkit-rshd
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell       Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql           MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd         distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc             VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
6697/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13           Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb            Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
43557/tcp open  mountd         1-3 (RPC #100005)
43662/tcp open  java-rmi        GNU Classpath grmiregistry
51796/tcp open  status         1 (RPC #100024)
52545/tcp open  nlockmgr        1-4 (RPC #100021)
MAC Address: 08:00:27:98:D9:CC (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

Appendix A (1 of 2): raw scan_full.txt output.

```

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 149.22 seconds
# Nmap 7.99 scan initiated Sun Aug 2 23:40:24 2026 as: /usr/lib/nmap/nmap --privileged -sV -p- -oN scan_full.txt 192.168.56.4
Nmap scan report for 192.168.56.4
Host is up (0.0043s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian Subuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          netkit-rshd
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell       Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql           MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd         distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc             VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
6697/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13           Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb            Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
43557/tcp open  mountd         1-3 (RPC #100005)

```

Appendix A (2 of 2): raw scan_full.txt output, continued.

Appendix B: iptables Ruleset (Full)

Before (`sudo iptables -L`):

```
Chain INPUT (policy ACCEPT)
target     prot opt source                destination
```

```
Chain FORWARD (policy ACCEPT)
target     prot opt source                destination
```

```
Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
```

Remediation commands applied:

```
sudo iptables -P INPUT DROP
sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
sudo iptables -A INPUT -p tcp -s 192.168.56.3 -j ACCEPT
```

After (sudo iptables -L -n):

```
Chain INPUT (policy DROP)
target     prot opt source                destination
ACCEPT     all  --  0.0.0.0/0              0.0.0.0/0
ACCEPT     all  --  0.0.0.0/0              0.0.0.0/0          state RELATED,ESTABLISHED
ACCEPT     tcp  --  192.168.56.3           0.0.0.0/0
```

```
Chain FORWARD (policy ACCEPT)
target     prot opt source                destination
```

```
Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
```